

Autenticación y Autorización

Login, sesiones, cookies, tokens, JWT, OAuth, OIDC, SSO, MFA y control de acceso.

Autenticación vs Autorización

La autenticación responde quién es el usuario. La autorización define qué puede hacer. Un usuario autenticado que accede a una función administrativa sin permiso representa una falla de autorización.

Sesiones y tokens

Las aplicaciones pueden usar cookies de sesión o tokens. JWT es un formato de token; OAuth 2.0 es un framework de autorización; OpenID Connect agrega una capa de identidad sobre OAuth 2.0.

SSO y MFA

Single Sign-On permite reutilizar una identidad entre aplicaciones. Multi-Factor Authentication exige factores adicionales y debe probarse en éxito, falla, recuperación y expiración.

Escenarios de QA

Valide credenciales inválidas, logout, expiración, acceso por rol, cambio de usuario, URLs protegidas, sesiones simultáneas y mensajes de error sin exposición innecesaria.

Cuándo utilizarlo

Utilice este conocimiento cuando el riesgo, la arquitectura o la etapa de entrega requieran este tipo de validación. Confirme objetivo, ambiente, datos necesarios y evidencias esperadas antes de comenzar.

Cómo lo aplica QA

Parta del comportamiento o riesgo que debe validarse, prepare datos y ambiente, ejecute la técnica o herramienta de forma reproducible y registre evidencias que ayuden al equipo a comprender el resultado.

Consejo de QA

Un login funcionando no demuestra que la autorización sea correcta: pruebe siempre roles y recursos protegidos.

Recursos oficiales

Site oficial: https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html